

IT-Security

An Introduction

IT-Sicherheit | 12.02.2026

Gerald Dißauer | Lecturer

A-SIT Secure Information Technology Center Austria

www.dhbw-stuttgart.de

Agenda

Introduction

Basic Principles for IT Security

Fundamentals about Information Security

Practical Observations from Conducted Projects

Discussions & Summary

Agenda

Introduction

Basic Principles for IT Security

Fundamentals about Information Security

Practical Observations from Conducted Projects

Discussions & Summary

LECTURE OBJECTIVE

WHY DO WE NEED SECURITY?

*One of the **most observed requirement** for a **product** (e.g., hardware, software, cryptographic product) in its lifecycle is **to function**.*

*However, those **products** should also **work** properly **under uncertain circumstances** such as **under malicious attack** or e.g., in **unprotected operation environments**.*

*Moreover, **communication** in a **secure** manner is also required **via unprotected networks** (e.g., the **internet**).*

KEYWORDS



RECENT OBSERVATIONS FROM INDUSTRY

SECURITY NEEDS TO BE INBUILT TO COUNTER ATTACKS

10/2009 | *“an application needs to be security aware so that it can protect itself from security threats. This implies [...] **security needs to be inbuilt** within the application”¹*

2018 | *“More and more organizations are accepting the fact that, despite their best efforts, **security breaches are unavoidable**. [...] It’s not a question IF your network will be breached, **the only question is WHEN**”²*

¹ cf. (Talukder et al., 2009, p. 1)

² cf. (Gemalto NV., 2018, p. 2, p. 16)

RECENT OBSERVATIONS FROM INDUSTRY | cont'd

100% SECURITY VERY HARD¹ TO ACHIEVE

05/2018 | *"I've been getting some weird press calls from reporters wanting to know if this demonstrates that e-mail encryption is impossible. No, this just demonstrates that **programmers are human and vulnerabilities are inevitable**. PGP² almost certainly has **fewer bugs than your average piece of software, but it's not bug free**."*³

09/2018 | *"No matter how much **resources** you **spend** for **security** systems, you become **not completely protected** against hacker **attacks**."*⁴

09/2019 | *"Technology alone can not protect a network."*⁵

¹ Which means it is almost impossible to be 100% secure

² PGP – Pretty Good Privacy

³ cf. (Schneier, 2018)

⁴ cf. (Bochman, 2018, p. 38); (G. Dißauer, Trans.) (Original work published 09/2018)

⁵ cf. (Winnefield, Kirchhoff, Upton, 2019, p. 21); (G. Dißauer, Trans.) (Original work published 02/2019)

RECENT OBSERVATIONS FROM INDUSTRY

CYBER EMERGENCY RESPONSE TEAM - NEWS & WARNINGS

07/2020 | *Critical Vulnerability in Microsoft Windows DNS Server - Patches and Workarounds Available*^{1,2}

08/2020 | *Goodbye EmoCrash - Fixed vulnerability in Emotet*³

09/2020 | *Domain controller takeover from the internal network: More details on CVE-2020-1472*⁴

09/2020 | *Critical vulnerability in Microsoft Exchange Server patches available*⁵

09/2021 | *Critical file-upload vulnerability VMWare vCenter Server*⁵

10/2021 | *Vulnerability (CVE-2021-41773) Apache HTTP Server 2.4.49 / 2.4.50*⁵

¹ Retrievable: <https://cert.at/de/> [Accessed: 01/02/2026]

² cf. Security warnings published by CERT.at

³ Security news published by CERT.at (*CERT – Cyber Emergency Response Team*)

⁴ cf. Security news published by CERT.at

⁵ cf. Security warnings published by CERT.at

SOME STATISTICS

SELECTED NUMBERS FROM KPMG STUDY¹

19% of businesses trust the security measures of their contractors

38% of businesses detected an increase in cyber attacks

60% of businesses were a victim of a cyber attack in the past 12 months

¹ KPMG Security Services GmbH (2021). *Cyber Security in Österreich, Studie, Advisory*, Vienna, Austria, April 2021

WHAT ARE PRACTICAL APPLICATION SCENARIOS? SECURITY MANAGEMENT IS NEARLY EVERYWHERE

- Automotive security
- Aerospace systems
- Digital Signature Systems (e.g., Handy-Signatur)
- (Mobile) Payment systems
- Electronic identities
- Healthcare Information Systems
- Internet of Things (IoT)
- [...]

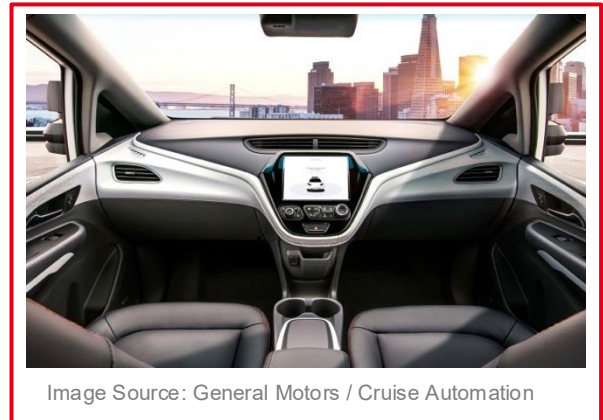


Image Source: General Motors / Cruise Automation

„Software is under malicious attack“

WHICH ORGANIZATIONS ARE ADDRESSED? THE SECURITY OF SYSTEMS

- Every organization
 - Every corporation
 - Every company
 - Every authority
- } If computer systems are operated

A lot of organizations prefer functionality ¹over security

¹ Annotation: Most of them do, because security management does not provide direct value such as increasing numbers of sales or similar.

SELECTED EXAMPLES OF ATTACKS

EXAMPLES OF AFFECTED ORGANIZATIONS

- **RSA Security (2011)** supply chain attack to access Lockheed Martin network
- **Yahoo (2013)** impact ca. 3B users – real names, email, personal data, phone
- **Marriott (2014)** impact ca. 500M users compromised credit card data
- **eBay (2014)** impact ca. 145M users personal data compromised
- **Uber Technologies (2016)** impact ca. 57M users personal data compromised
- **Wendy's (2016)** impact ca. 40M credit card data compromised (> 1.000 restaurants)
- **Fedex (2017)** USD 400M losses determined by NotPetya attack
- **Merck (2017)** USD 870M cost of NotPetya attack
- **Reckitt Benckiser (2017)** USD 129M cost of NotPetya attack
- [...]

CHALLENGES IN THE SECURITY DOMAIN

SELECTED OBSERVATIONS FROM CONDUCTED PROJECTS

- Function over security is most peoples priority
- Projects with pressure (*time, resources, quality, external factors*)
- Programming / coding is simple, everyone can do this job (*honestly ?*)
- Security and usability should be integral parts of systems and shouldn't be mutual exclusive
- Software development processes vary (*e.g., Adaptive/agile, V-Model, Waterfall*)
- Security is not a one-off project, it is a process
- Security is often very hard to measure¹ and it is often very hard to understand
- Software testing with a focus on functional tests
- The security guys most of the day provide the answer „No“

¹ Annotation: Compared to usual Key Performance Indicators (KPI). However, it is measurable if a critical system is down.

CHALLENGES IN THE SECURITY DOMAIN | cont'd

SELECTED OBSERVATIONS FROM CONDUCTED PROJECTS

- Computer systems are more and more connected
- Creative attackers (*e.g., Phishing, Spear Phishing, DDoS¹-Attacks*)
- Data transmission via wireless connections (*e.g., Bluetooth, RFID², WiFi³*)
- Mobility increases (*e.g., Notebook, Smartphone, Smartwatch, Tablet*)
- Zero-Day-Exploits
- Weakest link principle

¹ DDoS – Distributed Denial of Service (Attack)

² RFID – Radio-Frequency Identification

³ WiFi – Wireless Fidelity (compare: WLAN – Wireless LAN; Local Area Network)

CHALLENGES IN THE SECURITY DOMAIN | cont'd

SELECTED OBSERVATIONS FROM CONDUCTED PROJECTS

- Distributed systems grow with a short time to market
- Distributed systems require the interaction of lots of components
- Every kind of software (*or technology*) is affected
 - Operating systems (*e.g., Android, iOS, Linux, Mac OS, Microsoft Windows*)
 - Applications (*e.g., Office, Java, Web Applications*)
- The complexity of (*software*) projects increases
- Know how of staff very hard to gather (i.e., very hard to find great specialists)
- The pure amount of data / information such as **CVE¹s**, **CWE²s**, News, Attacks etc.

¹ CVE – Common Vulnerabilities and Exposure

² CWE – Common Weakness Enumeration

Agenda

Introduction

Basic Principles for IT Security

Fundamentals about Information Security

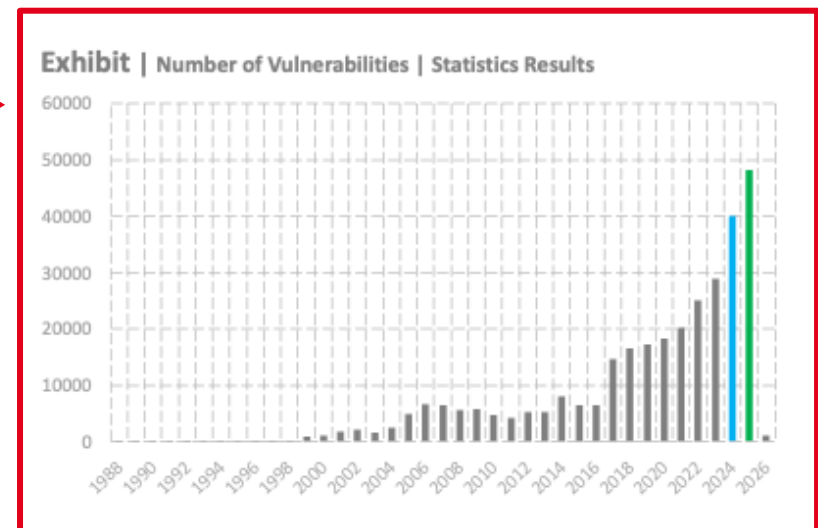
Practical Observations from Conducted Projects

Discussions & Summary

A SOFTWARE SECURITY PROBLEM INCREASING VULNERABILITIES FOR DECADES

„A [...] critical aspect of the computer security problem is a software problem. [...] malicious intruders can hack into systems by exploiting software defects. [...] and] Security holes in software are common.“¹

- A growing problem (1988-2026)²
- A security-related challenge
- Increasing vulnerabilities observed ³
- More reports to CERT/CC⁴



¹ cf. (McGraw, 2006, p. xix)

² cf. (NIST, National Vulnerability Database, 2026) [Accessed: 12/01/2026]

³ Annotation: The year 2026 is not completely included due to course date.

⁴ CERT/CC – Computer Emergency Response Team Coordination Center

WHAT DO SECURITY GUYS CARE ABOUT? ASSETS, RISK, AND SECURITY PROPERTIES

- Identifying the assets and their security properties is a crucial first step of every security analysis
- Deriving the risk profile helps to select appropriate security measures (*in reality*)
- Detect so-called low-level assets

Which assets do you have on your Smartphone?

THE OLD FASHIONED WAY OF THINKING

TARGET: EVERYTHING IS DONE, NOW WE ARE SECURE

- Cut the cords and thinking isolated
- If we had the resources (*e.g. money, people, technology, time*) we would have perfect security
- Identifying risk once before we start the project
- Isolated perimeter security should fit the gap
- Keep all & everything out of our systems
- People? Yeah – people are resources (*even if we have 2020, currently...*)
- Security? Of course – but it's IT's job
- Start one security project and explore what we basically might achieve if we succeed
- We can add-on security layers later if needed

DETECT AND RECOVER WAY OF THINKING

TARGET: MANAGING RISKS CONTINUOUSLY

- Assume that we are breached and it happens permanently and again and [...]
 - Detect intruders and act on a risk-basis
 - Identify threats and prioritize them
 - Implement security controls
 - Limit feasible damage to assets
 - Recover from incidents
- Conduct continuous risk management
- Consider risk early and begin with PM¹
- Consider potential and active incidents
- Perform risk-based resource allocation
- Security is a peoples problem (*internal vs. external*)

THREAT POTENTIAL

MALICIOUS ATTACKERS VARY

The attack potential depends on:

- Skill level
- Budget
- Man-power
- Time

THREATS

SELECTED EXAMPLES FOR CORPORATIONS

What are possible threats for IT infrastructure components?

- Attack via a known OS¹ vulnerability
- Destruction of infrastructure due to fire incident
- Outage of old hardware
- Physical access to server hardware
- Remote access to internal computer systems for unauthorized entities
- Security misconfiguration of components
- Unavailability (*e.g., due to power failure*)

Attacks happen. The only question is when.

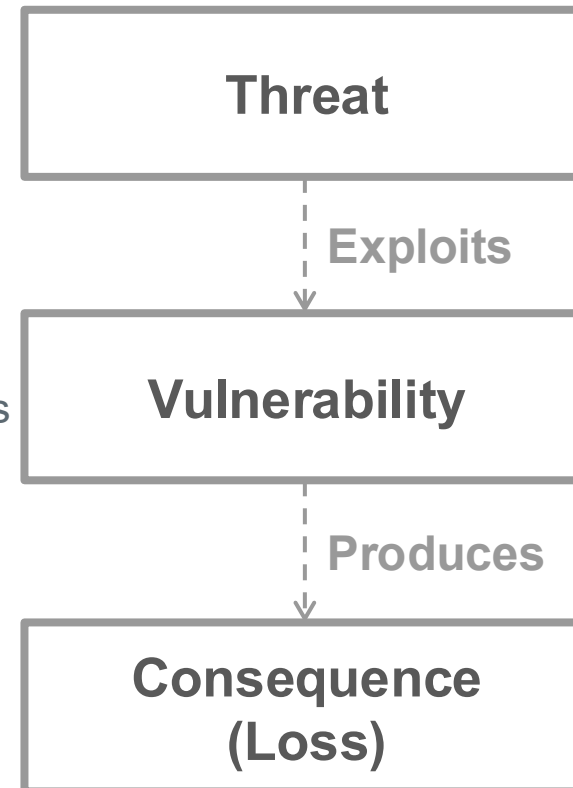
¹ OS – Operating System

WHAT HAPPENS IF THREAT BECOMES REALITY? CONSEQUENCES OCCUR

Threat. A cyber act, occurrence or event that exploits one or more vulnerabilities and leads to an adverse consequence or loss.

Vulnerability. A flaw/weakness in an information system, system security procedures, internal controls, or implementation that one or more threats could exploit to produce an adverse consequence or loss; a current condition that leads to or enables security risk.

Consequence. The loss that results when a threat exploits one or more vulnerabilities; the loss is measured in relationship to the status quo (*i.e., current state*).



THREAT MODELING

GATHER ALL ASSETS, THREATS, AND RISKS

Before implementing security controls, conduct threat modeling

Choose layer of abstraction wisely to conduct threat modeling

STRIDE Threat Model

- **S**poofing
- **T**ampering
- **R**epudiation
- **I**nformation Disclosure
- **D**enial of Service
- **E**levation of Privilege

THREATS AND ATTACK TREES

GROUP THREATS TO FORM ATTACK TREES

Threats specify what might go wrong and the sum of threats describes what makes the violation of a security property possible to a certain extent.

Threats can be grouped, hierarchically in different granularity.

Hierarchically grouped threats form an attack tree

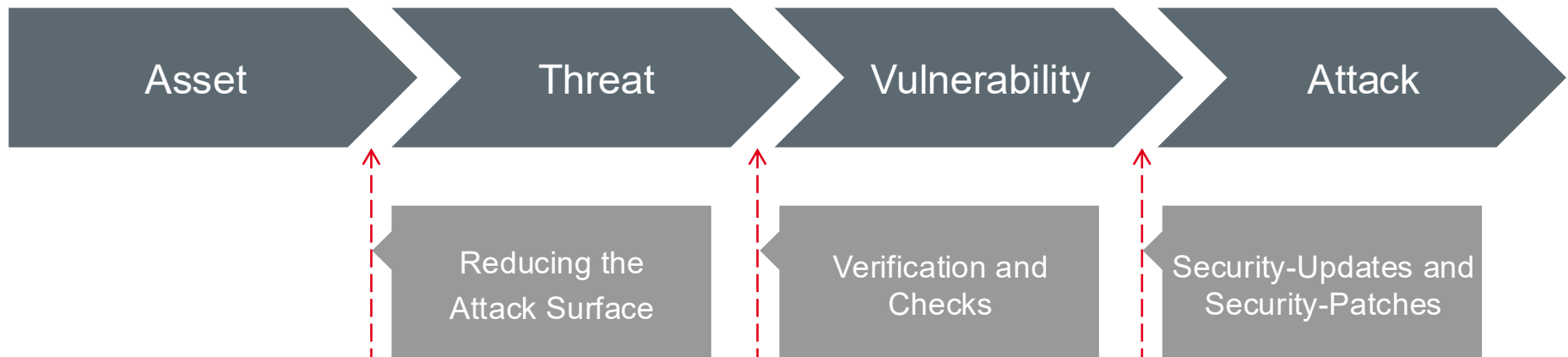
WHAT ARE ATTACKS?

WEAKNESSES IN SYSTEMS ARE EXPLOITED

Attack

An Attack is a particular attempt to violate at least one (*or more*) security property of an asset.

The path from an asset to an attack (*via threat and vulnerability*)



CATEGORIZATION OF ATTACKS

6 SELECTED ATTACK TYPES

Attack types consolidated in 6 categories

- Fraud
- Denial of Service attacks
- Destructive attacks
- Theft of intellectual property
- Identity theft
- Brand theft

Attacks can be differentiated

ATTACK DIFFERENTIATION

5 SELECTED ATTACK TYPE CHARACTERISTICS

Attack types consolidated in 6 different characteristics

- Anonymity
- Automatization
- Complexity
- Remote attacks
- Spreading attack techniques

Security is a fundamental basis to enable systems function properly under uncertain circumstances

GENERAL GUIDELINES TO BUILD SECURE SYSTEMS

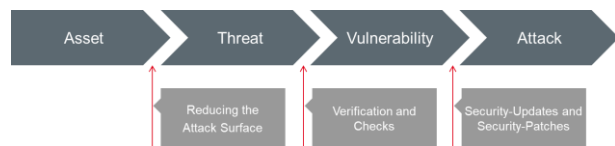
BREAKING THE LINKS

The 3 links aggregated

- (1) From asset to threat
- (2) From threat to vulnerability
- (3) From vulnerability to attack



Path from asset to attack



From asset to threat

Build security in and consider it in the lifecycle

Do not add security on top

From threat to vulnerability

Apply standardized security mechanisms

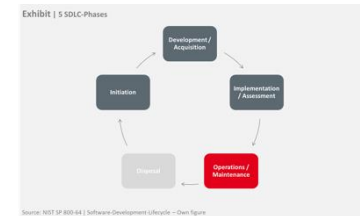
Proof, Security-Testing, Verification

From vulnerability to attack

Prepare for detect & recover

Update-Management, Logging

BUILD SECURITY IN SELECTED SUGGESTIONS



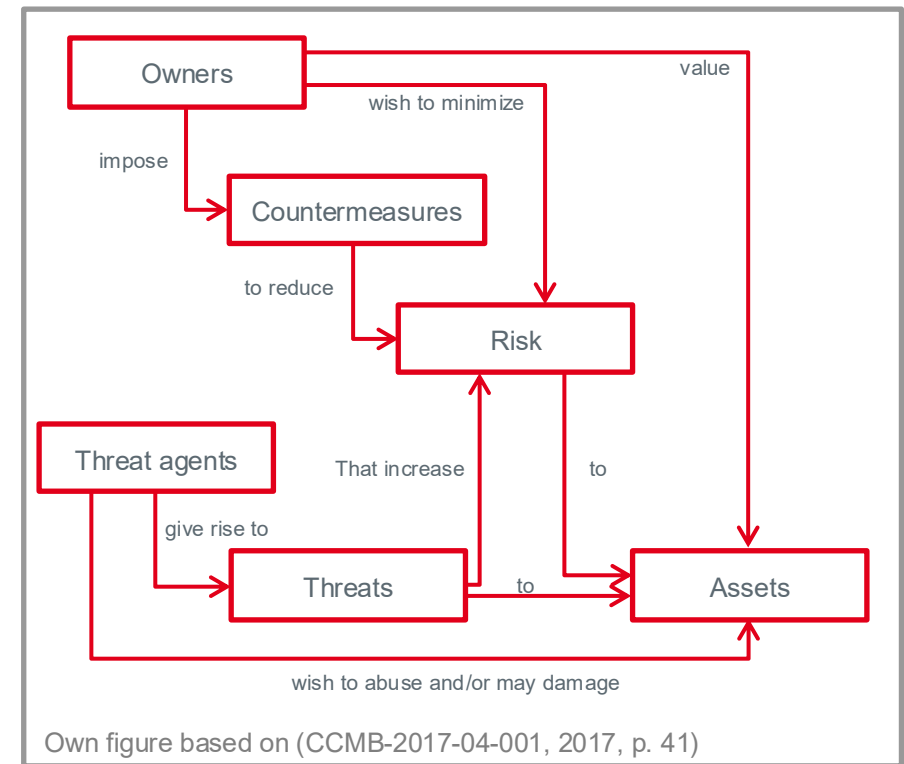
- *Data protection by design* and *data protection by default*¹ require security considerations at early phases (e.g. from the beginning)
- Design and integrate both security and functionality into the software development lifecycle (SDLC) phases and create secure products
- Understand the risks, the (*security*) requirements, the goals and the constraints to build (*or acquire*) appropriate computer systems
- Make informed decisions to construct reliable software or processes
- Operate, maintain and dispose software-intensive systems trustworthy

¹ cf. REGULATION (EU) 2016/679 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)

GENERAL SECURITY MODEL | OVERVIEW

SECURITY CONCEPTS AND RELATIONSHIPS¹

- Security in terms of asset protection; Asset = somebody places value upon
- Feasible loss of asset (1) confidentiality, (2) integrity and (3) availability
- Threats give rise to assets, based on likelihood that a threat is realized and the impact on the asset.
- Owners may be held responsible for the asset; Threat agents put value on it.
- Countermeasures are (1) sufficient and/or correct. It includes both IT and non-IT countermeasures and reduce the risk to the asset.



SECURITY PROPERTIES

CATEGORIES OF SECURITY NEEDS

3 degrees

- Normal
- High
- Very High

or alternative 4 degrees

- Low
- Medium
- High
- Very high

¹ Alternatives such as CI5A (*i.e.*, Confidentiality, Integrity, Availability, Authentication, Authorization, Accounting, and Anonymity) possible

IT-SECURITY AND COSTS

RESULTS ARE OFTEN INVISIBLE

Great security work is *(unfortunately)* often invisible

- Return on Investment (*ROI*)
- Cost/benefit very hard to measure
- Experiences for attacks and impacts such as costs
- Probability for specific attacks
- Law and judicial frameworks
- Service Level Agreements (*SLAs*)

THE 4 PHASES OF AN ATTACK AGGREGATED

RESULTS OFTEN INVISIBLE

- (1) Collect data about the target
- (2) Exploit a vulnerability
- (3) Keep alive the access to the systems
- (4) Blur traces and marks



PROPOSED SOLUTIONS

CONSIDER SECURITY IN THE PRODUCT LIFECYCLE

Security and architecture, design principles

- Integrate security early in the lifecycle
- Specify tasks, clearly
- Specify interfaces, clearly
- Make (extensive) use of standards
- Conduct testing in terms of security

2 Basic types of solutions

- Organizational solutions
- Technical solutions

**Consider products as
software-intensive products**

ORGANIZATIONAL SECURITY CONTROLS

SELECTED EXAMPLES

Organizational security controls

- Information security management system (ISMS) e.g., ISO 27001
- Policies (e.g., security policy, risk management policy, data protection policy)
- Strategies (e.g., recovery strategy, risk mitigation strategy)
- Monitoring (e.g., access control monitoring)
- (Supply chain) risk management
- Plans (e.g., business continuity plan, emergency plan, disaster recovery plan)
- Risk assessment and analysis (e.g., architectural risk assessment)



TECHNICAL SECURITY CONTROLS

SELECTED EXAMPLES

TECHNICAL SECURITY CONTROLS

- Private key backup
- Computer security controls
- Cryptography
- Life cycle technical controls
- System development controls
- Security management controls
- Life cycle security controls
- Network security controls

TYPICAL SYSTEM'S SECURITY TECHNIQUES

3 SELECTED MECHANISMS



CRYPTOGRAPHY

QUICK OVERVIEW

2 kinds of cryptographic techniques

- Symmetric techniques (*e.g., AES¹, DES², EES³, TDES⁴*)
- Asymmetric techniques (*e.g., DSA⁵, ECC⁶, ECDSA⁷, RSA⁸*)

¹ AES – Advanced Encryption Standard

² DES – Data Encryption Standard

³ EES – Escrowed Encryption Standard

⁴ TDES – Triple DES

⁵ DSA – Digital Signature Algorithm

⁶ ECC – Elliptic Curve Cryptography

⁷ ECDSA – Elliptic Curve Digital Signature Algorithm

⁸ RSA – Rivest Shamir Adleman

Agenda

Introduction

Basic Principles for IT Security

Fundamentals about Information Security

Practical Observations from Conducted Projects

Discussions & Summary

WHAT DOES INFORMATION SECURITY MEAN?

THE SAFETY & SECURITY OF DATA AND INFORMATION

Objective: Keeping secrets secret with balanced security measures

- **Safety:** more in terms of avoiding human damage
- **Security:** more in terms of avoiding the violation of a security property (*or security objective*) of an asset.

WHEN DO WE NEED SECURITY?

REQUIRED IN THE LIFECYCLE OF SYSTEMS

- **Security Objectives.** Confidentiality, Integrity, Availability (CIA)¹
- **Risk-based Methodologies.** Informed decision-making to protect assets
- **Security Processes.** Consider security with development processes
- **Security Requirements.** Blueprints for Software (e.g. *Protection-Profiles*)
- **Security Techniques.** Apply security solutions and security controls

¹ Alternatives such as CI5A (i.e., Confidentiality, Integrity, Availability, Authentication, Authorization, Accounting, and Anonymity) possible

WHEN DO WE NEED SECURITY? | cont'd

REQUIRED IN THE LIFECYCLE OF SYSTEMS

- **Security Techniques.** Apply security solutions and security controls
- **Follow Best-Practices.** Use norms, standards, and best practices as baseline standards (*e.g., BSIMM¹, CMMI^{®2}, Common Criteria, DIN³, ISO⁴, IEC⁵, IEEE⁶, MS-SDL⁷, NIST⁸, PCI-DSS⁹, SOG-IS-Crypto-Catalogue¹⁰*)
- **Continuous Improvement.** Efforts to achieve permanent optimization

¹ BSIMM – Building Security In Maturity Model

² CMMI[®] – Capability Maturity Model Integration

³ DIN – Deutsches Institut für Normung

⁴ ISO – International Organization for Standardization

⁵ IEC – International Electrotechnical Commission

⁶ IEEE – Institute of Electrical and Electronics Engineers

⁷ MS-SDL – Microsoft Security Development Lifecycle

⁸ NIST – National Institute of Standards and Technology

⁹ PCI-DSS – Payment Card Industry Data Security Standard

¹⁰ SOG-IS – Senior Officials Group Information Systems Security

WHICH SECURITY OBJECTIVES ARE RELEVANT?

3 SELECTED SECURITY OBJECTIVES¹

CIA-Triade

- **Confidentiality** (*is a property that applies to data/information such that it is not made available or disclosed to unauthorized entities*)
 - **Integrity** (*can apply to data/information or a service/system such that changes can only be made in a specified and by authorized entities*)
 - **Availability** (*can apply to data/information or a service/system such that there is timely and reliable access to the data/information or service*)
- Independent security properties²

**Implement Security Controls to counter the loss of an asset:
Confidentiality, Integrity, and/or Availability**

¹ Alternatives such as CI5A (i.e., Confidentiality, Integrity, Availability, Authentication, Authorization, Accounting, and Anonymity) possible

² Annotation: If something is only encrypted, it still can be altered. If something is only protected in terms of integrity, it cannot be kept secret

CIA-TRIAD AS CORE CONCEPT TO PROTECT ASSETS

PROTECT ASSETS WITH SECURITY FUNCTIONS

Information security guideline defines the information security objectives („*protection targets*“) to protect information assets (*e.g., classified information*) with **security controls**

- Confidentiality
 - Integrity
 - Availability
 - Authenticity
 - Non-repudiation
 - Reliability
 - Access Control
 - Accountability
- **CIA-Triade** (*alternatively CI5A¹ possible*)

¹ CI5A – Confidentiality, Integrity, Availability, Authentication, Authorization, Accounting, and Anonymity

CONFIDENTIALITY

SELECTED EXAMPLES

Security controls to achieve confidentiality to control access to data

- Access control (*physical, technical e.g., passwords, 2FA¹, SCAL²*)
- Encryption of data at rest (*database encryption, disk/drive encryption, container*)
- Encryption of data in transit (*IPSec³, PKI⁴, SSH⁵, SSL/TLS⁶, symmetric, asymmetric*)

Ensure that the wrong guys are not capable in gaining access to sensitive data and ensuring that the right guys can access it

¹ 2FA – 2 Factor Authentication

² SCAL – Sole control assurance level (e.g., SCAL1, SCAL2 under CEN EN 419 241-1)

³ IPSec – Internet Protocol Security

⁴ Public Key Infrastructure

⁵ SSH – Secure Shell

⁶ SSL/TLS – Transport Layer Security (formerly known as: Secure Sockets Layer)

INTEGRITY

SELECTED EXAMPLES

Security controls to achieve accuracy, consistency, and trustworthiness of data

- Access control (*Physical and technical*)
- Configuration management
- Change control and version control (*e.g., GIT, SVN*)
- Digital signatures (*e.g., signing documents, software*)
- Hashing (*HMAC, SHA-1, SHA-2, SHA-256, SHA-512*)
- Transmission cyclic redundancy check (*CRC*) functions

Avoid modifications by unauthorized users

¹ HMAC - Keyed-Hash Message Authentication Code

² SHA-1 – Secure Hash Algorithm 1 (*e.g.,*)

³ SHA-2 – Secure Hash Algorithm 2 (*e.g., SHA-256, SHA-384, SHA-512, SHA-512/224, SHA-512/256*)

AVAILABILITY

SELECTED EXAMPLES

Security controls to achieve reliable and continuous access to data by authorized entities

- Clustering (*e.g., MongoDB sharded cluster replica sets, active/active DB2 cluster*)
- DDoS¹-mitigation or WAF² (*e.g., Barracuda, Fortinet, MS Azure WAF*)
- Load balancing (*e.g., layer 4 and layer 7 load balancing*)
- RAID³ or Backup (*e.g., RAID0 – no redundancy, RAID1 - mirroring, RAID5 – performance & parity*)
- Redundant data and lines (*inbound, outbound, e.g., TAP⁴*)
- Emergency, business continuity, or disaster recovery plan (*e.g., BSI 100-4*)

¹ DDoS – Distributed Denial of Service

² WAF – Web Application Firewall

³ RAID Redundant Array of Independent Disks

⁴ TAP – Turnkey Access Point

WHY CARE ABOUT RISK?

THREATS ARE OUTSIDE

- Threats specify what might go wrong with data/information or a service/system
- It describes a potential violation in terms of security. The sum of all threats describes everything that can result to a violation of a security property of the asset
- Threats can be grouped to hierarchical classes of a threats that form an attack tree

Which assets do you have on your Smartphone?

COMPONENTS OF RISK¹

POTENTIAL EVENT | CONDITION | LOSS



- **Potential Event.** An act, occurrence, or happening that alters current conditions and leads to a loss.
- **Condition.** The current set of circumstances that leads to or enables risk.
- **Consequence.** The loss that results when a potential event occurs; the loss is measured in relationship to the status quo (*i.e., current state*).

¹ cf. (Mead and Woody, 2016, pp. 19-20)

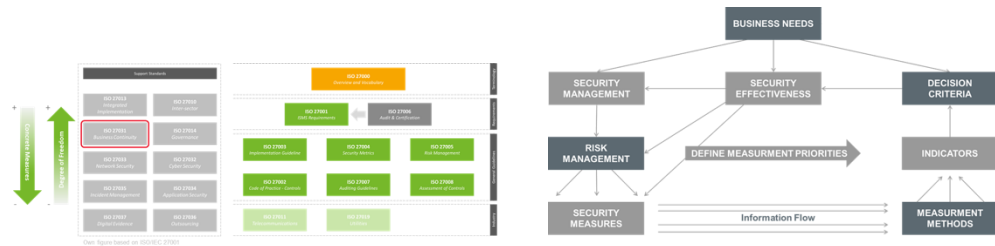
² Annotation: A condition is a passive event from a risk perspective. Thus, it does not cause an entity to suffer a loss or an adverse consequence.

³ Annotation: The length of time before a risk is realized or the length of time in which action can be taken to prevent a risk.

HOW CAN WE CLASSIFY SECURITY CONTROLS?

4 GROUPS OF SECURITY CONTROLS AGGREGATED

- **Preventive** (< 100%, *encryption*)
- **Detective** (e.g., *IDS¹, IPS²*)
- **Reactive** (*measures, etc.*)
- **Communication**
(e.g., *escalation, emergency management, crisis management*)



Combine both organizational and technical security controls

THE PROPERTIES OF SECURITY CONTROLS

SHIFT THE PROBLEM TO AN EASE TO PROTECT ASSET

Security in terms of (*risk-based*) asset protection

- (1) Identify an asset
- (2) Install security controls
- (3) Shift the problem to another asset
- (4) Install security controls

Case: Consider a file containing sensitive data.

Solution 1: Protect the file with a passphrase. Newly identified assets: passphrase, password checking function

Solution 2: Encrypt the file obtaining the new assets: cryptographic key, software for encryption

Agenda

Introduction

Basic Principles for IT Security

Fundamentals about Information Security

Practical Observations from Conducted Projects

Discussions & Summary

SOME EXPERIENCES FROM CONDUCTED PROJECTS

SELECTED OBSERVATIONS

- „*Security is IT's job*“
- „*Let's conduct a one-off project and then we are done*“
- Integrate security at the early beginning (*e.g., first objectives/requirements*)
- Perform continuous (*architectural*) risk assessment (*at least*) during development
- Detect problems early
- Build software securely from the beginning
- Re-use sound techniques
- Secure software development based on established methodologies

SOME EXPERIENCES FROM CONDUCTED PROJECTS | cont'd

SELECTED OBSERVATIONS

Recommendations

- **Integrate security early** at the beginning
- **Consider security** in the **lifecycle**, continuously
- **Understand** and **apply** both **organizational** and **technical security controls**
- **Take** the **operational environment into account**
- **Decide** on a **risk basis** about measures

Agenda

Introduction

Basic Principles for IT Security

Fundamentals about Information Security

Practical Observations from Conducted Projects

Discussions & Summary

SUMMARY

COVERED TOPICS

- **Clarified both IT and information security fundamentals**
- **Explored security vulnerabilities**
- **Discussed practical relevance of IT security and information security**
- **Presented attacks, threats, vulnerabilities and security controls**
- **Identified operational and technical security controls**
- **Discussed experiences from conducted projects and QSCD certifications**

